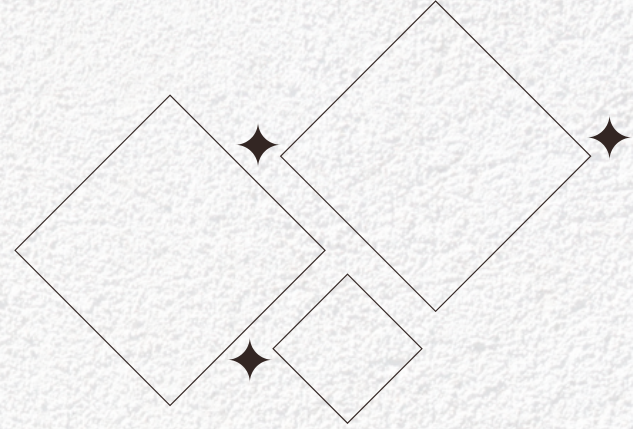




Act1- Analisis de ciberataque

CNO IV Programación WAP

Maestro: Servando López Contreras

Luis Emmanuel Aronia Silva - 182979

Erik Del Angel Arriaga Torres - 181653

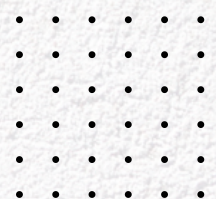
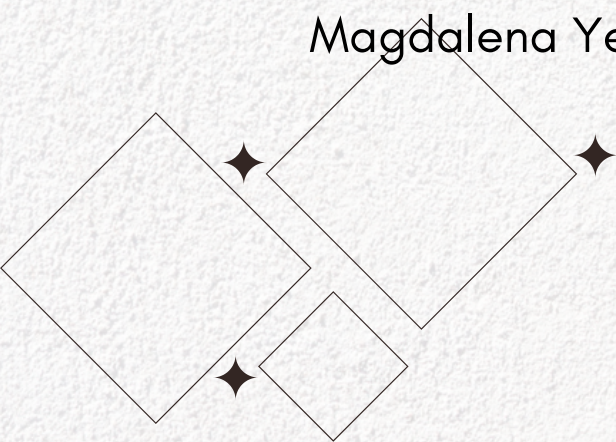
Lizbeth Guerrero Hurtado - 172068

Guzmán Martínez Bryhan Eduardo - 178508

Lopez Alcocer Monica Isabel - 179827

Bruno Axel Puente Luna - 177876

Magdalena Yesenia Tristán Rivera - 174702



ÍNDICE

Cronología y evolución del ciberataque al Banco de Chile (2018).....	1
1. Contexto general del ataque	2
2. Caracterización técnica del ciberataque al Banco de Chile	3
3. Evaluación del impacto del ciberataque mediante el modelo CIA .	5
4. Estimación del impacto económico y costo total del ciberataque ..	6
5. Lecciones aprendidas y recomendaciones	7
5.1. Fallas críticas detectadas	7
5.2. Buenas prácticas y políticas recomendadas	8
5.3. Recomendaciones aplicables al contexto mexicano o latinoamericano ...	8
5.4. Conclusión	8
6. Fuentes consultadas	9

Cronología y evolución del ciberataque al Banco de Chile (2018)

A continuación, se presenta una línea de tiempo que permite identificar las principales etapas del incidente, desde la intrusión y preparación inicial hasta su investigación posterior, destacando los hechos clave, las vulnerabilidades o debilidades de seguridad observadas y las medidas adoptadas como consecuencia del ataque.

FECHA / ETAPA	HECHO CLAVE	VULNERABILIDAD O DEBILIDAD ASOCIADA
ANTES DEL 24 DE MAYO DE 2018	Intrusión y preparación del ataque. Antes de realizar el robo, los atacantes debieron conseguir presencia dentro de la infraestructura del banco, realizar reconocimiento y obtener acceso a sistemas relacionados con las transferencias internacionales. El momento exacto del acceso inicial no fue publicado.	No se hizo pública una CVE concreta. Por el modus operandi atribuido posteriormente a APT38, las principales debilidades potenciales fueron el compromiso de credenciales, controles insuficientes sobre cuentas privilegiadas, segmentación de red y monitoreo de actividad anómala.
24 DE MAYO DE 2018	Aparece malware destructivo en la red del Banco de Chile. Numerosos equipos resultaron afectados, generando una contingencia tecnológica que inicialmente concentró la atención del banco en recuperar sus sistemas.	La capacidad del malware para propagarse y afectar numerosos equipos evidencia la importancia de la segmentación de red, protección de endpoints y mecanismos de recuperación.
24-25 DE MAYO DE 2018	El malware funciona como distracción. Mientras el personal técnico atendía el incidente informático, los atacantes ejecutaron el componente financiero del ataque.	Una vulnerabilidad fundamental fue la dificultad para correlacionar simultáneamente un incidente destructivo con operaciones financieras anómalas. La respuesta se concentró inicialmente en el malware.
DURANTE EL ATAQUE	Transferencias fraudulentas mediante SWIFT. Los atacantes consiguieron emitir órdenes de transferencia internacionales fraudulentas. El monto robado fue de aproximadamente US\$10 millones, enviado, según los reportes periodísticos, hacia cuentas en el extranjero, particularmente en Hong Kong.	Controles insuficientes de autenticación, supervisión o validación de operaciones SWIFT, además de posible acceso indebido a sistemas o credenciales utilizados para generar las órdenes. No existen datos públicos suficientes para afirmar exactamente qué credencial o mecanismo técnico fue vulnerado.

FINALES DE MAYO - PRIMEROS DIAS DE JUNIO DE 2018	Investigación y recuperación. El banco reconstruye equipos afectados y comienza a determinar que el malware destructivo no era necesariamente el objetivo principal, sino parte de una operación de fraude financiero más amplia.	El incidente muestra una deficiencia de visibilidad integral de seguridad: endpoint, red y sistemas financieros necesitaban ser analizados de forma conjunta para detectar el verdadero objetivo.
9 DE JUNIO DE 2018	Banco de Chile confirma públicamente el robo. El gerente general, Eduardo Ebersperger, informó que aproximadamente US\$10 millones habían sido sustraídos y explicó que el virus había funcionado como una distracción para realizar el fraude.	Se confirma que la organización enfrentó un ataque de múltiples etapas, combinando sabotaje informático y fraude financiero.
13 DE JUNIO DE 2018	Respuesta del sector financiero chileno. Autoridades financieras y el Ministerio de Hacienda analizaron el incidente y buscaron asesoramiento especializado en ciberseguridad para fortalecer las capacidades del sector bancario.	El caso puso en evidencia la necesidad de mejorar la coordinación sectorial, intercambio de información sobre amenazas, respuesta a incidentes y estándares comunes de ciberseguridad.
3-4 DE OCTUBRE DE 2018	El ataque es vinculado con APT38. Investigaciones de FireEye/Mandiant relacionaron el caso con operaciones financieras atribuidas a APT38, grupo vinculado por investigadores y autoridades estadounidenses a Corea del Norte.	APT38 se caracteriza por obtener acceso prolongado a entidades financieras, estudiar procesos internos, atacar sistemas relacionados con SWIFT y utilizar malware destructivo para borrar evidencias o distraer a las víctimas.
2019 EN ADELANTE	El incidente se convierte en referencia para el fortalecimiento de la ciberseguridad financiera chilena. Reportes posteriores analizan cómo el ataque impulsó cambios en gestión de riesgo, regulación y preparación frente a incidentes cibernéticos.	Necesidad de avanzar hacia defensa en profundidad, controles sobre infraestructura crítica, gobernanza del riesgo cibernético y mejores capacidades de respuesta.

1. Contexto general del ataque

El 24 de mayo de 2018, el Banco de Chile, una de las principales instituciones financieras del país, fue víctima de un ciberataque que afectó miles de equipos de su red interna y

que posteriormente se relacionó con un fraude financiero mediante el sistema internacional de transferencias SWIFT. Mientras un malware destructivo provocaba fallas masivas en computadores y servidores, los atacantes realizaron transferencias fraudulentas hacia cuentas en el extranjero por un monto aproximado de US\$10 millones. El incidente fue posteriormente asociado con operaciones atribuidas a APT38, grupo vinculado a campañas de cibercrimen financiero contra instituciones bancarias de distintos países.

En cuanto a las condiciones de ciberseguridad previas, el caso evidenció debilidades relacionadas con la protección y supervisión de los sistemas críticos. La segmentación entre la red corporativa y los entornos vinculados con operaciones financieras no habría sido suficiente para impedir que una intrusión evolucionara hacia sistemas de mayor importancia. Asimismo, las capacidades de monitoreo y detección resultaron insuficientes para identificar oportunamente la actividad de los atacantes durante las etapas previas al fraude. La atención inicial se concentró principalmente en contener el malware destructivo y recuperar los equipos afectados, debido a que este parecía representar la amenaza principal.

Entre los factores que facilitaron el ataque destacaron elementos técnicos y organizacionales. Desde el punto de vista técnico, la limitada segmentación de la red, la posible utilización de credenciales comprometidas y las dificultades para detectar comportamientos anómalos favorecieron el avance de los atacantes. En el aspecto organizacional, la naturaleza híbrida del incidente representó un desafío para la respuesta del banco, ya que el sabotaje de los equipos funcionó como una cortina de humo mientras se desarrollaba el fraude financiero. El caso demuestra que las instituciones financieras deben estar preparadas para enfrentar ataques simultáneos y coordinados, manteniendo la vigilancia de sus sistemas críticos incluso durante incidentes de gran impacto operativo.

2. Caracterización técnica del ciberataque al Banco de Chile

La siguiente tabla presenta una caracterización técnica del incidente, considerando el tipo de ataque, el posible actor involucrado, los vectores de acceso utilizados, las vulnerabilidades y debilidades asociadas, las etapas de ejecución, los sistemas comprometidos, así como los mecanismos de detección y respuesta. Este análisis permite observar que el incidente no correspondió a una acción aislada, sino a una operación compuesta por diferentes fases orientadas a facilitar la realización de transferencias fraudulentas y dificultar su detección.

Elemento	Descripción
----------	-------------

Tipo de ataque	Robo cibernético financiero (fraude en transacciones del sistema SWIFT). El ataque finaliza con sabotaje mediante malware destructivo (wipers) y ransomware para destruir evidencia y entorpecer investigaciones.
Actor o grupo atacante	APT38 (Se suele agrupar estos ataques bajo el nombre "Lazarus" grupo con motivaciones financieras patrocinado por el régimen de Corea del Norte).
Vector de entrada	Sitios web comprometidos estratégicamente (watering holes), búsqueda y compromiso de servidores Linux vulnerables, y correos de spear-phishing (campañas llevadas a cabo por operadores norcoreanos asociados).
Vulnerabilidad explotada	Vulnerabilidades de Apache Struts2 (en servidores Linux). Adicionalmente, el malware SMOOTHIDE explota las vulnerabilidades CVE-2016-4119, CVE-2016-1019, o CVE-2015-8651. También utilizan credenciales comprometidas.
Etapas del ataque (MITRE ATT&CK)	Se realizaron 6 etapas para sus ataques: 1. Recopilación de información, 2. Compromiso inicial, 3. Reconocimiento interno, 4. Pivote a servidores SWIFT, 5. Transferencia de fondos, 6. Destrucción de evidencia.
Sistemas o servicios comprometidos	Servidores de la aplicación SWIFT Alliance, estaciones de trabajo SWIFT, bases de datos SQL de Oracle, servidores Linux, y la red interna en general (llegando a inutilizar hasta 10,000 computadoras y servidores en un solo incidente).
Duración del incidente	El grupo permanece dentro de la red comprometida por un promedio de 155 días (con un máximo registrado de 678 días) dedicados al reconocimiento antes de ejecutar el robo.
Mecanismos de detección y respuesta	Desde la perspectiva del atacante, evaden software antivirus actualizando sus herramientas rápidamente al ser detectados. Como respuesta global de la industria, SWIFT implementó un "Customer Security Programme" en mayo de 2016.

3. Evaluación del impacto del ciberataque mediante el modelo CIA

El impacto del ciberataque al Banco de Chile puede analizarse mediante el modelo CIA, uno de los fundamentos principales de la seguridad de la información, compuesto por los principios de confidencialidad, integridad y disponibilidad. En este incidente, los tres componentes resultaron afectados en distintos niveles: la confidencialidad se vio comprometida por el acceso no autorizado a credenciales y sistemas internos; la integridad fue vulnerada mediante la alteración de sistemas y la ejecución de operaciones financieras fraudulentas; y la disponibilidad se vio afectada por la interrupción y desconexión de miles de equipos y servicios bancarios. La siguiente tabla relaciona cada uno de estos principios con las consecuencias observadas durante el ataque y presenta evidencia del caso que permite dimensionar su impacto sobre la operación y la seguridad de la institución.

Principio	Descripción del impacto	Evidencia del caso
Confidencialidad	Exfiltración de credenciales operativas y mapas de red. Los atacantes comprometieron las credenciales de acceso de alto nivel del sistema transaccional SWIFT y la topología de red interna del banco tras una fase prolongada de reconocimiento sin ser detectados.	"Los ciberdelincuentes de Lazarus Group (APT38) obtuvieron acceso no autorizado y credenciales clave para interactuar directamente con la plataforma SWIFT, permitiéndoles autorizar y enviar giros financieros hacia cuentas de destino en Hong Kong." (MITRE ATT&CK Group G0082 / Reportes de Ciberseguridad).
Integridad	Corrupción destructiva de sistemas informáticos y adulteración de órdenes de pago. Se alteró deliberadamente el Master Boot Record (MBR) y el código de arranque de miles de computadores mediante malware. Paralelamente, se inyectaron registros transaccionales fraudulentos dentro de la plataforma SWIFT.	"Encontramos que el virus no era necesariamente el tema de fondo, sino que al parecer querían defraudar al banco... nos dimos cuenta de que el virus era una cortina de humo." (Eduardo Ebensperger, citado en Redacción El Dínamo, 2018).

Disponibilidad	Parálisis masiva de la red operativa y sucursales. Desconexión e inoperatividad total de más de 9,000 computadoras de escritorio y cientos de servidores a nivel nacional. Esto provocó la suspensión de la atención en cajas y la interrupción prolongada de servicios en sucursales físicas para evitar la propagación del malware.	“El ataque obligó a desconectar y dejó fuera de servicio aproximadamente a 9,000 computadores y 500 servidores en las sucursales de todo Chile, paralizando la atención presencial al público durante varios días.” (Comisión para el Mercado Financiero - CMF Chile / Fondo Monetario Internacional - IMF, 2024).
-----------------------	--	---

4. Estimación del impacto económico y costo total del ciberataque

Parámetros de Conversión y Marco Metodológico Para la cuantificación financiera del incidente del Banco de Chile (24 de mayo de 2018), se aplica el marco de estimación económica de ciberpérdidas de **Adrian Mizzi**. La conversión de los valores expresados originalmente en dólares estadounidenses (USD) a Pesos Mexicanos (MXN) utiliza el tipo de cambio oficial publicado por el Banco de México (Banxico) para la fecha de la brecha: **\$19.5664 MXN / USD**.

Tipo de costo	Descripción	Estimación (MXN)
Pérdidas operativas	Fondo robado vía SWIFT (\$10,000,000 USD / \$195.66M MXN) e inactividad comercial de 385 sucursales físicas por 3 días (\$1,500,000 USD / \$29.35M MXN).	\$225,013,600 MXN
Daños reputacionales	Campañas de comunicación de crisis, mitigación de pérdida de clientes corporativos y retención patrimonial (\$2,000,000 USD).	\$39,132,800 MXN
Costos técnicos	Servicios forenses DFIR (Mandiant, Microsoft), reemplazo de 9,000 discos duros inutilizados y reconstrucción del entorno SWIFT (\$3,500,000 USD).	\$68,482,400 MXN

Costos legales / regulatorios	Auditorías regulatorias obligatorias ordenadas por la SBIF/CMF, sanciones y honorarios jurídicos (\$1,200,000 USD).	\$23,479,680 MXN
Pago de rescate o extorsión	No aplica. El código malicioso ejecutado por APT38 fue un <i>wiper (MBRlper)</i> destructivo; no existió solicitud de rescate ni extorsión.	\$0 MXN
TOTAL ESTIMADO	Suma total de pérdidas económicas consolidadas en moneda mexicana (MXN)	\$356,108,480 MXN

Comparativa con el Presupuesto Anual de Ciberseguridad del Sector Financiero

En 2018, el presupuesto anual estimado dedicado exclusivamente a Ciberseguridad y Seguridad de la Información para una institución bancaria de Nivel 1 en América Latina oscilaba entre **\$15,000,000 USD** y **\$25,000,000 USD (\$293,496,000 a \$489,160,000 MXN)**.

Proporción sobre el Presupuesto Anual: El costo total del ciberataque (**\$356,108,480 MXN**) representó entre el **72.8%** y el **121.3%** de todo el presupuesto anual de ciberseguridad de la entidad.

Conclusión Económica: En un evento único de 24 horas, la institución perdió una cifra equivalente al presupuesto completo invertido en defensas digitales durante todo un año, evidenciando la asimetría económica entre el costo de prevención defensiva y el costo real de remediación tras un ataque persistente avanzado (APT).

5. Lecciones aprendidas y recomendaciones

El ciberataque al Banco de Chile permitió identificar diversas debilidades técnicas y organizacionales que incrementaron el impacto del incidente y facilitaron que una operación destructiva funcionara como distracción para ejecutar un fraude financiero. A partir del análisis del caso, es posible reconocer las principales fallas de seguridad, establecer buenas prácticas para fortalecer la protección de infraestructuras críticas y proponer recomendaciones aplicables al sector financiero mexicano y latinoamericano. Estas medidas buscan reducir la probabilidad de incidentes similares y mejorar las capacidades de prevención, detección, respuesta y recuperación de las instituciones.

5.1 Fallas críticas detectadas

- Segmentación insuficiente de la red: La separación entre la red corporativa y los sistemas críticos de pago, como SWIFT, resultó insuficiente para limitar movimientos laterales y accesos indebidos.

- Respuesta enfocada en el ataque visible: La atención se concentró principalmente en contener el malware destructivo, mientras las operaciones fraudulentas continuaban en paralelo.
- Capacidades limitadas de detección: La dependencia de antivirus tradicionales y la falta de herramientas EDR/XDR dificultaron la identificación temprana de actividades anómalas.
- Debilidad organizacional: No se contempló adecuadamente la posibilidad de que el malware destructivo funcionara como una distracción para ocultar un ataque financiero simultáneo.

5.2 Buenas prácticas y políticas recomendadas

- Segmentación y Zero Trust: Separar estrictamente los sistemas SWIFT y core bancario de la red corporativa, utilizando controles de acceso, autenticación multifactor y servidores intermediarios seguros.
- Monitoreo continuo: Implementar EDR/XDR, SIEM y un SOC con vigilancia 24/7 para correlacionar eventos y detectar comportamientos anómalos.
- Protocolos ante ataques de distracción: Establecer playbooks que mantengan la supervisión de sistemas financieros críticos incluso durante incidentes masivos.
- Resiliencia operativa: Mantener respaldos desconectados, planes de recuperación probados y realizar ejercicios periódicos de simulación y Red Team.

5.3 Recomendaciones aplicables al contexto mexicano o latinoamericano

- Cumplimiento normativo: Alinear los controles de seguridad con disposiciones de Banxico y CNBV, además de marcos internacionales como ISO/IEC 27001 y NIST Cybersecurity Framework.
- Cooperación sectorial: Compartir indicadores de compromiso e inteligencia de amenazas entre bancos, CSIRT, CERT y organismos financieros regionales.
- Protección de sistemas de pago: Mantener redes independientes para plataformas como SPEI y SWIFT, aplicar MFA y realizar auditorías y pruebas de penetración periódicas.
- Preparación ante incidentes: Implementar monitoreo permanente, protocolos contra ataques combinados y simulaciones que contemplen ingeniería social, movimiento lateral, fraude y malware destructivo.

5.4 Conclusión

El ataque al Banco de Chile de 2018 demuestra que un incidente aparentemente enfocado en destruir o paralizar sistemas puede ocultar un objetivo financiero de mayor alcance. El uso del malware como mecanismo de distracción evidenció la importancia de contar con una defensa en profundidad que combine segmentación de redes, monitoreo continuo, detección avanzada y procedimientos de respuesta preparados para atender múltiples amenazas simultáneamente. Asimismo, las pérdidas económicas y afectaciones operativas derivadas del incidente confirman que la ciberseguridad debe considerarse un elemento esencial para la continuidad y sostenibilidad de las instituciones financieras. En el contexto mexicano y latinoamericano, fortalecer la cooperación sectorial, adoptar estándares internacionales y proteger especialmente los sistemas de pago de alto valor son acciones fundamentales para reducir el riesgo frente a amenazas similares.

6. Fuentes consultadas

- Banco de México. (2018, 24 de mayo). *Tipo de cambio para resolver obligaciones denominadas en moneda extranjera pagaderas en la República Mexicana (24/05/2018)*. <https://www.banxico.org.mx/tipcamb/>
- Banco de Chile loses \$10 million in SWIFT-related attack. (s. f.). BankInfoSecurity. <https://www.bankinfosecurity.com/banco-de-chile-loses-10-million-in-swift-related-attack-a-11075>
- BioBioChile. (2018, 9 de junio). *Robaron US\$10 millones en ataque informático al Banco de Chile: Virus fue un distractor*. <https://www.biobiochile.cl/noticias/nacional/chile/2018/06/09/robaron-us10-millones-en-ataque-informatico-al-banco-de-chile-virus-fue-un-distractor.shtml>
- Carnegie Endowment for International Peace. (2020). *Timeline of cyber incidents involving financial institutions: Banco de Chile incident*. Cyber Policy Initiative. <https://carnegieendowment.org/features/fincyber-timeline>
- Cimpanu, C. (2018, 11 de junio). *Hackers crashed a bank's computers while attempting a SWIFT hack*. BleepingComputer. <https://www.bleepingcomputer.com/news/security/hackers-crashed-a-bank-s-computers-while-attempting-a-swift-hack/>
- Comisión para el Mercado Financiero. (2018). *Informe y procedimiento sancionatorio por incidente operativo en Banco de Chile*. Superintendencia de Bancos e Instituciones Financieras. <https://www.cmfchile.cl>
- ESET Research. (2018, 13 de junio). *Chile busca asesoramiento en ciberseguridad tras ciberataque al Banco de Chile*. WeLiveSecurity. <https://www.welivesecurity.com/la-es/2018/06/13/chile-busca-asesoramiento-en-ciberseguridad-tras-ciberataque-al-banco-de-chile/>
- FireEye. (2018). *APT38: Un-usual suspects: Special report on North Korean financial cyber crime group*. Mandiant Threat Intelligence. <https://www.mandiant.com/resources/reports/apt38-details-group-financial-cyber-crime>
- Fondo Monetario Internacional. (2024). *Cyber risk and financial stability* (IMF Working Paper No. 2024/042). IMF eLibrary. <https://www.elibrary.imf.org/view/journals/002/2024/042/article-A002-en.xml>
- Kaspersky Lab. (2017). *Lazarus under the hood*. Kaspersky Lab Global Research & Analysis Team (GReAT).
- Leyden, J. (2018, 12 de junio). *Hackers target payment transfer system at Chile's biggest bank, "take \$10m"*. The Register. https://www.theregister.com/2018/06/11/chile_bank_wiper_prelude_cyberheist/

- MITRE. (s. f.). APT38 (G0082). MITRE ATT&CK. <https://attack.mitre.org/groups/G0082/>
- Nick. (2018, 12 de junio). Crooks used a KillDisk wiper in an attack against Banco de Chile as diversion for a SWIFT hack. Cyber Defense Magazine. <https://www.cyberdefensemagazine.com/crooks-used-a-killdisk-wiper-in-an-attack-against-banco-de-chile-as-diversion-for-a-swift-hack/>
- Optaris. (s. f.). Piratas informáticos norcoreanos están vinculados al fraude con SWIFT por valores cercanos a 100 millones de dólares. <https://www.optaris.com/piratas-informaticos-norcoreanos-estan-vinculados-al-fraude-con-swift-por-valores-cercanos-a-100-millones-de-dolares/>
- Redacción El Dínamo. (2018, 9 de junio). Los detalles del ciberataque que terminó con el robo de 10 millones de dólares al Banco de Chile. El Dínamo. <https://www.eldinamo.cl/pais/2018/06/09/los-detalles-del-ciberataque-que-termino-con-el-robo-de-10-millones-de-dolares-al-banco-de-chile/>
- Seals, T. (2018, 13 de junio). Banco de Chile wiper attack just a cover for \$10M SWIFT heist. Threatpost. <https://threatpost.com/banco-de-chile-wiper-attack-just-a-cover-for-10m-swift-heist/132796/>